Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)

Evidence-Driven Cryptographic Visibility for Post-Quantum Readiness

Theme: Blockchain & Cybersecurity | Institution: Sri Sairam Engineering College | State: Tamil Nadu | Participation: Individual

Abstract

Enterprises run cryptography in source code, third-party libraries, compiled binaries, container images, configuration files and certificates, yet rarely hold a single, trustworthy inventory of where and how it is used. This gap blocks risk assessment and delays migration to quantum-resistant algorithms. This brief presents ECDAT, a proposed modular platform that discovers cryptographic usage across heterogeneous software artifacts, attaches evidence and confidence scores to every finding, routes uncertain findings to manual triage, ranks results using business criticality, and emits use-case-based post-quantum cryptography (PQC) recommendations together with a CycloneDX-compatible Cryptography Bill of Materials (CBOM).

Scope note. This document describes the proposed design. Technologies and capabilities listed under future scope are not claimed as implemented or tested; the exact implementation stack will be documented according to what is actually used.

1. Motivation and Problem Formulation

Security teams must answer three questions about cryptography: *what* is used, *where* it is located, and *how* it is used. Hidden usage through transitive dependencies and compiled binaries makes these questions hard, and the absence of centralized visibility prevents prioritized remediation and migration planning toward quantum-resistant cryptography.

Formal statement. Let $A = \{a_1, ..., a_n\}$ be the set of software artifacts of an enterprise, each mapped to an application with a business-criticality value. ECDAT seeks a set of findings F, where each finding $f = (\text{asset, location, usage, } E_f, c_f)$ carries an evidence set E_f and a confidence c_f in [0, 1], together with a priority ordering over F and a CBOM that serialises the validated findings.

Evaluation questions (planned). (RQ1) Does correlating evidence across artifact types improve detection reliability over single-artifact analysis? (RQ2) Does confidence scoring concentrate manual review effort on genuinely uncertain findings? (RQ3) Is the generated CBOM complete and schema-valid?

2. System Architecture

ECDAT is organised as a seven-stage, evidence-driven workflow with independent modules, so each stage can be developed and tested separately. Figure 1 shows the pipeline with the output of each stage; Figure 2 shows the component view.

Output of each stage shown beneath its block.

Figure 1. End-to-end pipeline: Artifact Collection to PQC Recommendations and CBOM Generation.

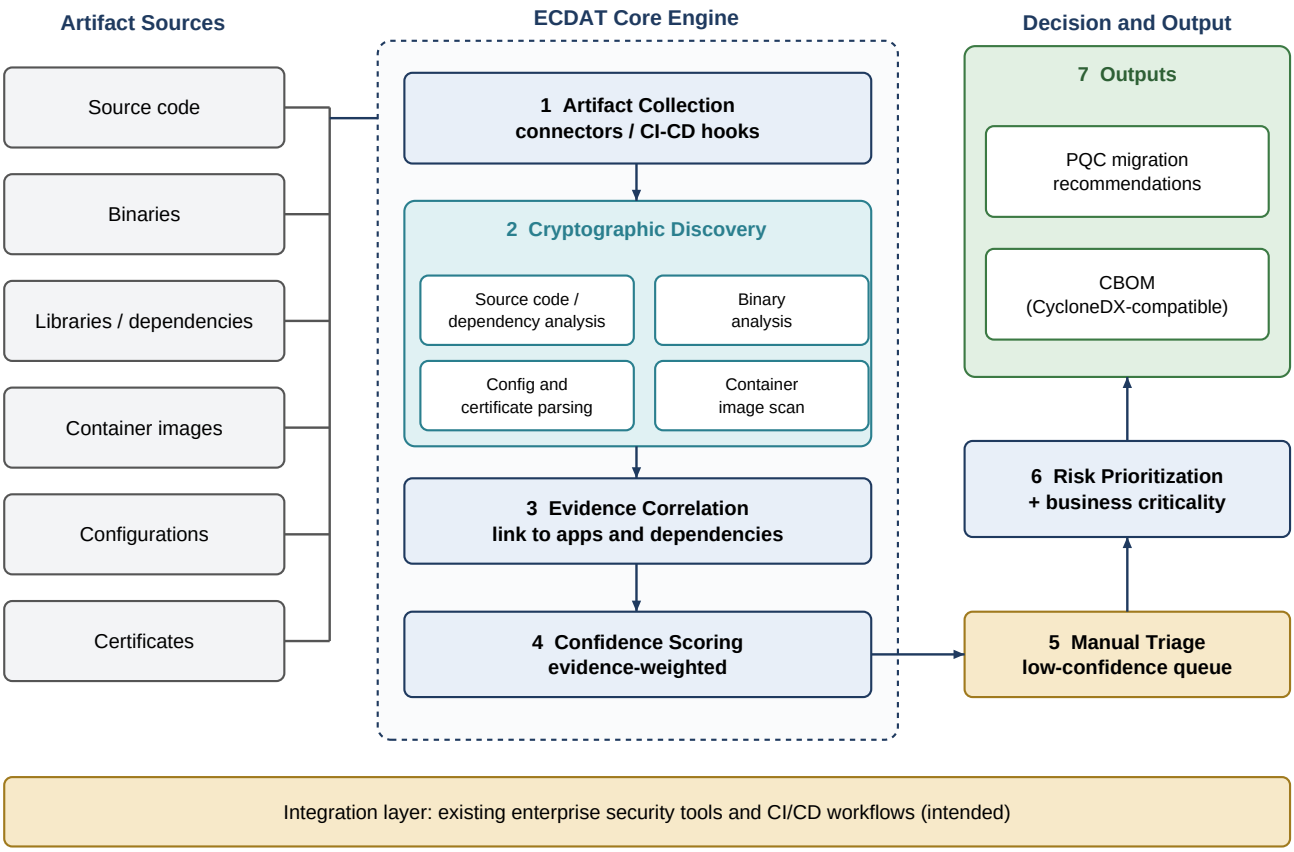

Figure 2. ECDAT block architecture: sources, core engine, decision stages and outputs.

3. Methodology

3.1 Multi-artifact cryptographic discovery

Each artifact type is handled by a dedicated analyzer. Every analyzer emits findings with their evidence, so reliability comes from combining weak and strong signals rather than trusting any single detector.

Artifact type	Discovery approach (proposed)	Typical evidence recorded
Source code	Pattern and syntax-level matching of cryptographic API calls and algorithm identifiers	File, line, API or identifier
Libraries / dependencies	Software composition analysis of manifests and lockfiles against known cryptographic libraries	Package, version, manifest path
Binaries	Static inspection of symbols, strings and linked-library signatures; generally lower certainty	Symbol or string match, library linkage
Container images	Unpack image layers and apply the analyzers above to the filesystem	Image, layer, file path
Configurations	Parse protocol and cipher settings (for example TLS parameters)	Config file, key, value
Certificates	Parse X.509 attributes such as key type, size and signature algorithm	Subject, key algorithm, validity

Table 1. Discovery strategy by artifact type.

3.2 Evidence correlation and confidence scoring

Findings that refer to the same cryptographic asset are linked across artifacts and associated with the owning application and its dependencies. An illustrative aggregation uses a noisy-OR form, $C = 1 - \text{prod}(1 - w_i e_i)$, where e_i is the strength of evidence item i and w_i a weight reflecting the reliability of its source analyzer. Independent corroborating evidence therefore raises confidence, while a lone weak signal (for example a string match in a binary) stays low. The exact weights and the threshold T are configuration parameters to be calibrated during evaluation.

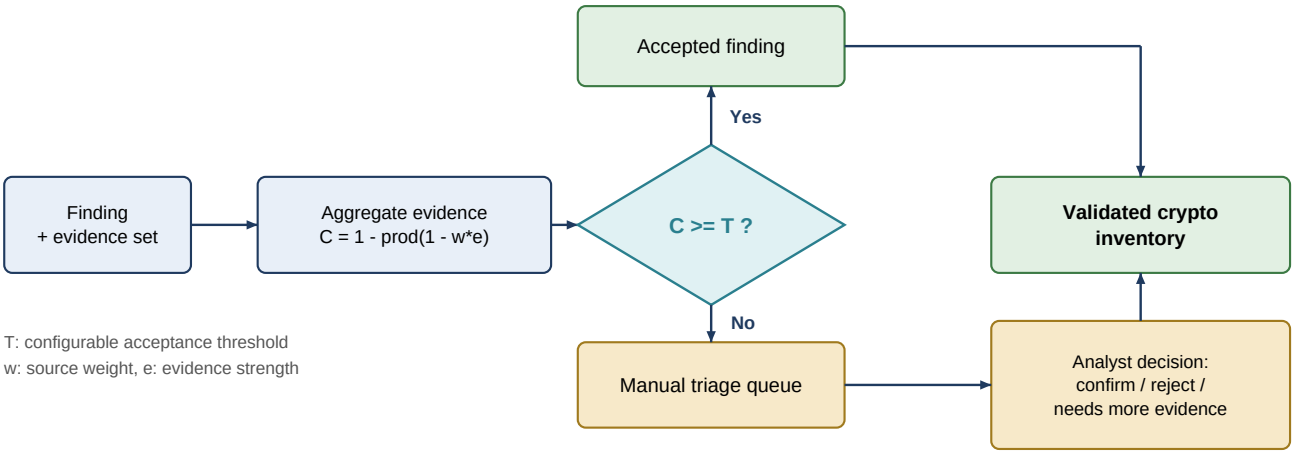

Figure 3. Confidence-based triage: findings below the threshold enter manual review before acceptance.

3.3 Risk prioritization

Validated findings are ranked using three inputs: the intrinsic cryptographic risk R of the algorithm or protocol (for example outdated primitives, or public-key schemes exposed to future quantum attacks), the confidence C of the finding, and the business criticality B of the application that depends on it. The ordering function f is a design choice to be tuned with security teams; the aim is that a moderately risky algorithm inside a business-critical application can outrank a riskier one in a low-value system.

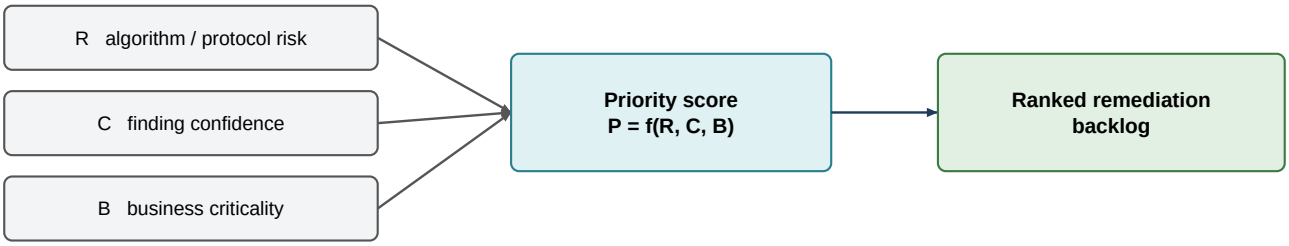

Figure 4. Risk prioritization: three inputs combine into a ranked remediation backlog.

3.4 PQC migration recommendations and CBOM

Recommendations are use-case based, mapping each discovered use of cryptography to a candidate standardized post-quantum option, and are subject to human validation. Final selection depends on performance, interoperability and compliance constraints, and hybrid deployment may be appropriate during transition.

Use case	Commonly found today	Candidate PQC direction
Key establishment / key exchange	RSA key transport, Diffie-Hellman, ECDH	ML-KEM (NIST FIPS 203)
Digital signatures	RSA, ECDSA	ML-DSA (NIST FIPS 204); hash-based SLH-DSA (FIPS 205) where suitable
Certificates and protocols	Classical key types and signature algorithms	Migration planned per use case once ecosystem support is confirmed

Table 2. Illustrative use-case mapping for recommendations.

The CBOM serialises validated findings in a CycloneDX-compatible structure. CycloneDX models cryptographic assets such as algorithms, certificates, protocols and related cryptographic material; ECDAT proposes to attach location, evidence, confidence and business context to each asset (exact property mapping to be fixed at implementation).

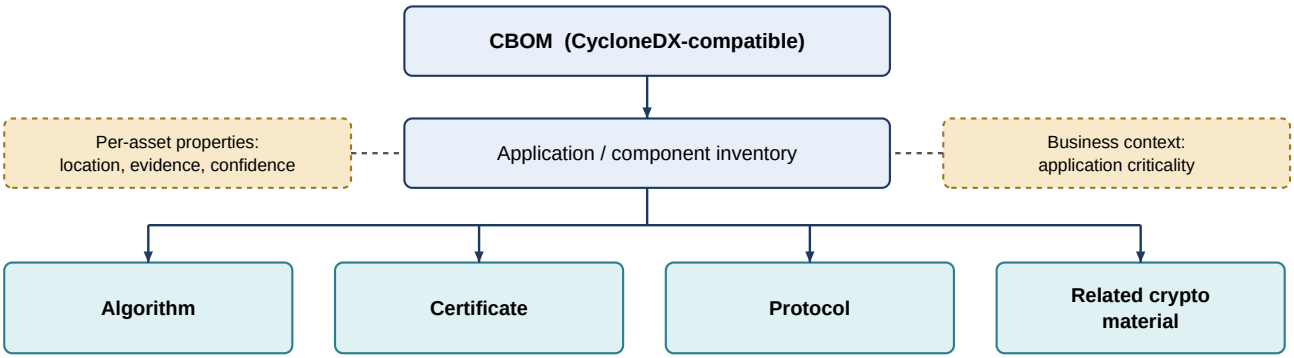

Figure 5. Proposed CBOM structure: applications, cryptographic asset types and per-asset properties.

4. Feasibility, Risks and Threats to Validity

ECDAT is software-only, needs no specialized hardware, and can reuse existing enterprise software artifacts and security data.

Challenge	Mitigation
Hidden cryptographic usage	Correlate findings across source code, binaries, dependencies, configurations and certificates
False positives	Confidence scoring with manual review of uncertain findings
Limited runtime visibility	Combine available static and artifact-based evidence; runtime visibility may need additional instrumentation
Enterprise-scale complexity	Prioritize by confidence, risk and business criticality
PQC migration uncertainty	Use-case-based recommendations subject to human validation

Table 3. Key challenges and mitigation strategies.

5. Planned Evaluation

No quantitative results are claimed in this brief. Evaluation is planned on a labelled corpus of artifacts with known cryptographic usage:

- **Detection quality:** precision and recall per artifact type, comparing single-artifact detection against correlated detection (RQ1).
- **Confidence calibration and triage load:** whether low-confidence findings are the ones analysts overturn, and the share of findings needing review (RQ2).
- **CBOM quality:** schema validity and completeness against the ground-truth inventory (RQ3).
- **Practicality:** scan time and integration effort within a CI/CD workflow.

6. Impact Potential

Stakeholder	Expected benefit
Enterprise security teams	Centralized visibility into cryptographic assets; identification of outdated or risky components; support for remediation prioritization
Application and DevOps teams	Earlier detection of cryptographic dependencies; tracking of cryptographic changes across releases; CI/CD integration
Enterprise management	Findings linked to business-critical applications; risk-based planning; long-term post-quantum readiness

Table 4. Stakeholder impact.

7. Innovation and Future Scope

The contribution lies in unifying cryptographic discovery, evidence correlation, confidence scoring, business-context prioritization and CBOM generation in one workflow. Future work may include improved binary analysis, deeper runtime visibility, expanded enterprise integrations and more detailed PQC migration planning; these are future work unless implemented and tested.

References

[1] NIST Post-Quantum Cryptography project. https://csrc.nist.gov/projects/post-quantum-cryptography
[2] NIST Cybersecurity Framework. https://www.nist.gov/cyberframework
[3] CycloneDX. https://cyclonedx.org/
[4] Smart India Hackathon. https://www.sih.gov.in/
[5] NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) and FIPS 205 (SLH-DSA), Post-Quantum Cryptography standards.